

Topik yang Anda minta mencakup seluruh rantai serangan dalam skenario Boot2Root (dari enumerasi sampai privilege escalation dan exfiltration). Untuk tujuan pembelajaran dan CTF/lab legal, saya akan menjelaskan konsep, alur pikir, contoh kasus, dan langkah tingkat tinggi yang aman. Saya tidak akan memberikan instruksi operasional rinci untuk menyerang sistem nyata tanpa izin.

Gambaran umum alur Boot2Root

Kill Chain (Ringkas)

Dari Enumerasi ke Root

Tujuan Boot2Root adalah mendapatkan akses awal ke sebuah mesin, lalu meningkatkan hak akses sampai menjadi root/administrator.

1. Service Enumeration

Memetakan layanan yang terbuka dan mengidentifikasi versi, konfigurasi, dan potensi kelemahan.

2. Service Exploitation

Memanfaatkan salah konfigurasi, kredensial lemah, atau kerentanan aplikasi untuk memperoleh akses awal.

3. CVE Exploitation

Menggunakan kerentanan yang sudah diketahui publik untuk mencapai eksekusi kode atau akses lebih lanjut.

4. Privilege Escalation

Menaikkan hak akses dari user biasa menjadi root melalui konfigurasi, binary, atau mekanisme sistem yang disalahgunakan.

5. Data Exfiltration

Mengakses atau memindahkan data yang menarik dari sistem target.

6. Recommendations

Memberikan mitigasi dan perbaikan untuk menutup jalur serangan yang ditemukan.

Dalam CTF/lab, setiap tahap biasanya dirancang agar peserta belajar satu teknik tertentu, misalnya SUID abuse, credential reuse, atau web RCE.

1. Service Level Enumeration

```
(root@kali)-[/home/kali/Documents/htb_linux/lame]
# nmap -A -Pn -T4 -p- 10.129.158.251
Starting Nmap 7.93 ( https://nmap.org ) at 2023-07-01 08:38 EDT
Nmap scan report for 10.129.158.251
Host is up (0.078s latency).
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 10.10.14.33
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 600fcfe1c05f6a74d69024fac4d56ccd (DSA)
|_2048 5656240f211ddea72bae61b1243de8f3 (RSA)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
```

Tujuan

Mengetahui layanan apa saja yang berjalan, versinya, dan kemungkinan titik masuk.

Yang dicari

1. Port terbuka

Contoh: 22/SSH, 80/HTTP, 139-445/SMB, 3306/MySQL.

2. Banner/version

Versi Apache, OpenSSH, Samba, dll.

3. Misconfiguration

Anonymous FTP, directory listing, default credentials, SMB guest access.

4. Attack surface

Web application, database, file share, API, admin panel.

Contoh kasus (lab/CTF)

Hasil scan menunjukkan:

Port Layanan

22 OpenSSH 7.x

80 Apache 2.4.x

445 Samba 4.x

Dari sini penyerang akan:

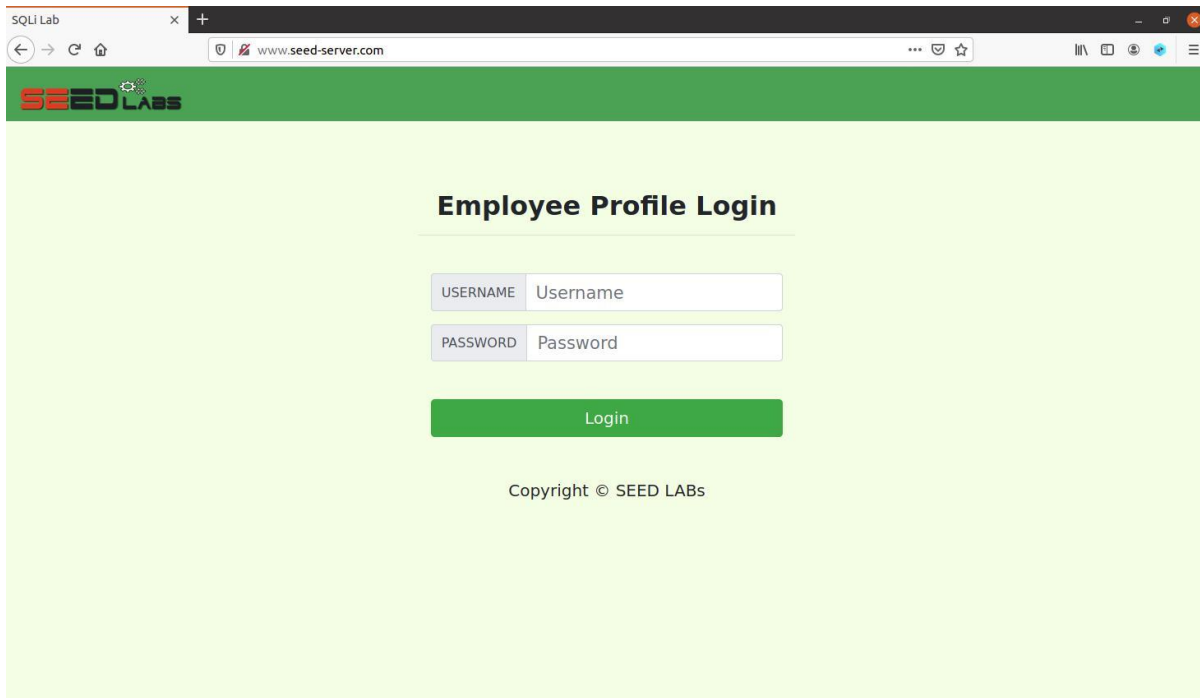
1. Mengakses website untuk mencari halaman tersembunyi.

2. Memeriksa apakah SMB mengizinkan guest access.
3. Mencocokkan versi layanan dengan database CVE.

Pembelajaran utama

Enumerasi sering kali lebih penting daripada eksploitasi. Banyak mesin CTF dapat dipecahkan hanya dengan menemukan file backup, kredensial yang bocor, atau share yang salah konfigurasi.

2. Service Level Exploitation



Tujuan

Mendapatkan akses awal dengan memanfaatkan kelemahan layanan.

Jenis umum

1. Default credentials

Admin/admin, root/toor, dll.

2. Weak credentials

Password mudah ditebak atau digunakan ulang.

3. Web vulnerabilities

LFI, file upload abuse, command injection, auth bypass.

4. Network service abuse

FTP write access, NFS misconfig, SMB share yang terlalu permisif.

Contoh kasus (lab/CTF)

Sebuah web app memungkinkan upload gambar tanpa validasi yang memadai. Penyerang mengunggah file yang dapat dieksekusi oleh server dan memperoleh akses shell terbatas.

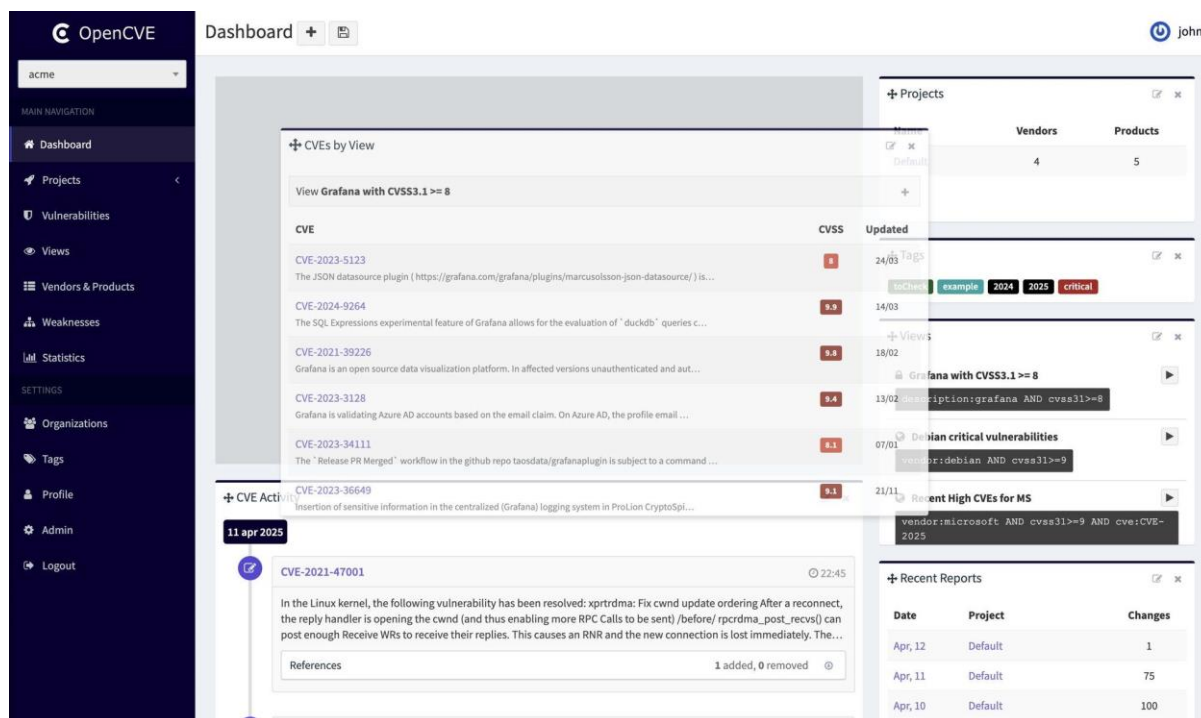
Alur umum:

1. Temukan fitur upload.
2. Uji jenis file yang diterima.
3. Amati apakah file disimpan dan diproses server.
4. Gunakan hasilnya untuk memperoleh akses awal.

Mitigasi

1. Validasi tipe file di server.
2. Jalankan proses upload di direktori non-eksekusi.
3. Gunakan autentikasi kuat dan MFA.
4. Batasi hak akses service account.

3. CVE Exploitation



Tujuan

Memanfaatkan kerentanan yang sudah diketahui publik.

Alur kerja etis (lab/CTF)

1. Identifikasi versi

Misalnya OpenSSH 7.2p2, Apache 2.4.29, Samba 4.5.9.

2. Cari CVE terkait

Gunakan NVD, vendor advisories, atau database exploit untuk mengetahui apakah versi tersebut memiliki kerentanan yang relevan.

3. Verifikasi kondisi eksploitasi

Tidak semua CVE dapat dieksploitasi; beberapa memerlukan konfigurasi tertentu.

4. Uji di lingkungan lab

Jangan pernah menguji di sistem tanpa izin.

Contoh terkenal (konseptual)

Samba "username map script" RCE (CVE-2007-2447): konfigurasi tertentu memungkinkan eksekusi perintah melalui fitur pemetaan username.

Pada mesin CTF, penyerang biasanya:

1. Mendeteksi versi Samba rentan.
2. Memastikan opsi konfigurasi yang diperlukan aktif.
3. Menggunakan exploit untuk mendapatkan akses shell.

Catatan: saya tidak memberikan payload atau langkah exploit rinci untuk sistem nyata.

Mitigasi

1. Patch management.
2. Asset inventory.
3. Vulnerability scanning berkala.
4. Disable fitur yang tidak diperlukan.

4. Data Exfiltration



Tujuan

Mengambil data dari sistem target setelah akses diperoleh.

Apa yang dicari

1. Credential files

SSH keys, config files, database passwords.

2. Application secrets

API keys, environment variables, token.

3. User data

Dokumen, database dump, backup files.

4. Configuration data

Network configs, service configs, deployment secrets.

Contoh kasus (lab/CTF)

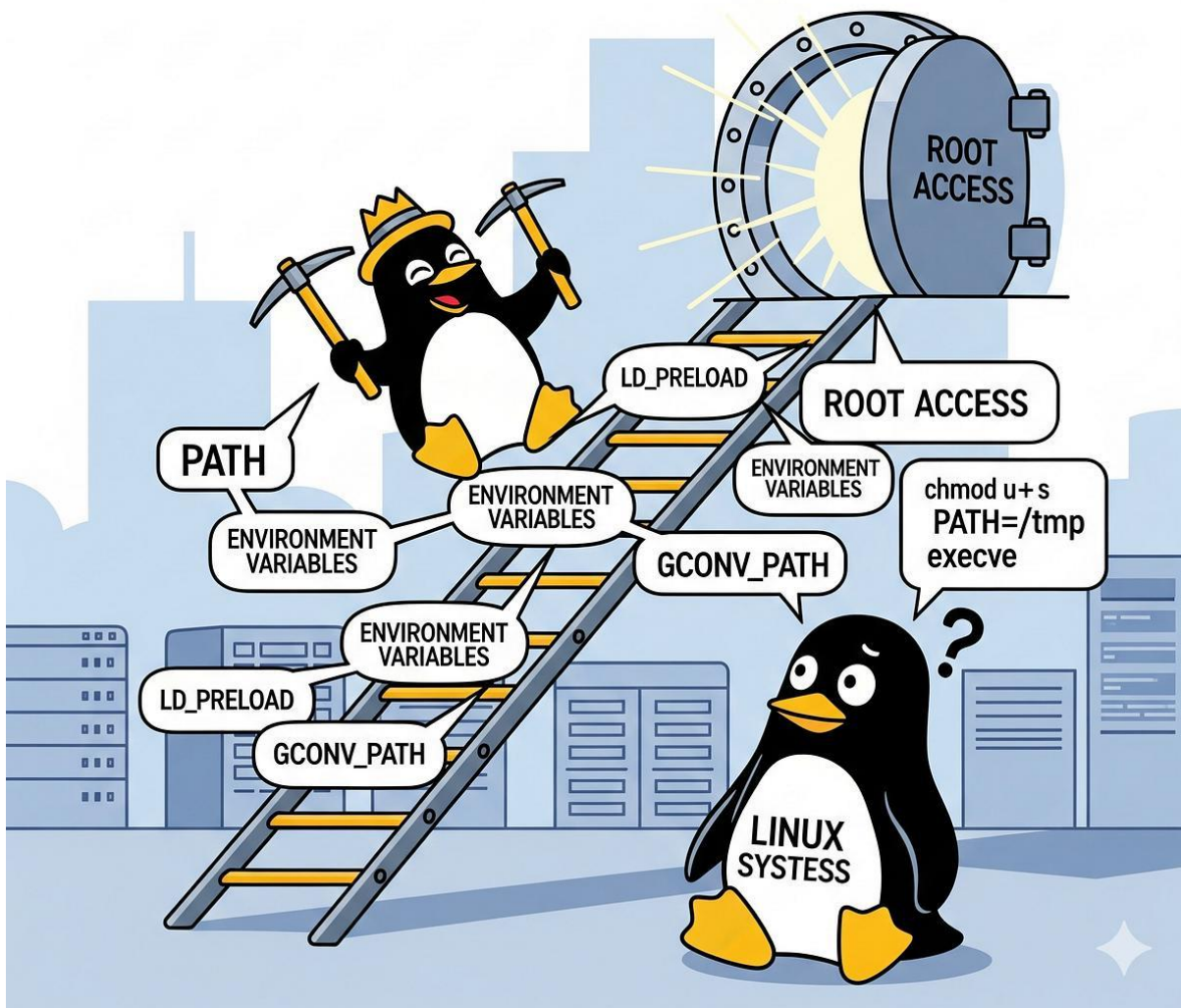
Setelah mendapatkan shell sebagai user www-data, penyerang menemukan file .env yang berisi kredensial database. Kredensial tersebut kemudian digunakan untuk mengakses database dan menemukan flag.

Mitigasi

1. Secret management yang benar.
2. Least privilege pada file dan database.
3. Encryption at rest dan in transit.
4. Monitoring akses data sensitif.

5. Privilege Escalation (Vertical & Horizontal)

SUID Environmental Variables Privilege Escalation



Konsep

Perbedaan Vertical vs Horizontal

Jenis	Tujuan
Vertical escalation	User biasa → root/admin

Horizontal escalation User A → User B dengan level setara

Dalam Boot2Root, fokus utama biasanya vertical escalation sampai mendapatkan root.

Teknik umum (Linux)

1. SUID/SGID misconfiguration

Binary dengan bit SUID dapat berjalan sebagai pemiliknya (sering root). Jika binary memungkinkan eksekusi program lain, itu dapat disalahgunakan.

Contoh CTF: binary custom root-SUID memanggil editor atau shell tanpa sanitasi.

2. sudo misconfiguration

User diizinkan menjalankan program tertentu sebagai root tanpa password.

Contoh CTF: `sudo /usr/bin/vim` atau program lain yang dapat membuka shell.

3. Cron jobs

Script yang dijalankan root secara berkala dapat dimodifikasi oleh user biasa.

Contoh CTF: `/opt/backup.sh` writable oleh semua user.

4. Capabilities

Linux capabilities memberi hak khusus pada binary tertentu.

Contoh: binary dengan `cap_setuid+ep` dapat mengubah UID proses.

5. Credential reuse

Password yang ditemukan pada aplikasi dipakai juga untuk SSH atau akun lain.

Contoh CTF: password database sama dengan password user sistem.

6. Kernel exploits

Kerentanan kernel digunakan untuk memperoleh root.

Catatan: ini biasanya tahap terakhir dan paling berisiko; hanya untuk lab yang sengaja dibuat rentan.

Contoh alur CTF: SUID abuse

1. Enumerasi menemukan file SUID tidak biasa.
 2. Binary tersebut dapat memanggil program eksternal.
 3. Dengan memanfaatkan perilaku itu, penyerang memperoleh shell dengan hak root.
- Inti pembelajaran: pahami mengapa memberi hak root pada binary tertentu berbahaya.

Living-Off-The-Land (LOTL)

Menggunakan alat bawaan sistem alih-alih malware khusus.

Contoh (konseptual)

1. `tar`, `cp`, `rsync` untuk memindahkan data.
2. `find`, `grep`, `locate` untuk enumerasi.
3. `ssh` untuk lateral movement jika kredensial ditemukan.
4. `systemctl`, `cron` untuk persistence di lab yang diizinkan.

LOTL populer karena sulit dibedakan dari aktivitas administratif normal.

6. Recommendations / Mitigasi

Dari sisi enumerasi

1. Tutup port yang tidak diperlukan.
2. Gunakan firewall dan segmentasi jaringan.

3. Hilangkan banner/version disclosure jika memungkinkan.

Dari sisi service exploitation

1. Ganti default credentials.
2. Terapkan MFA untuk akses administratif.
3. Validasi input dan upload file dengan ketat.
4. Jalankan layanan dengan akun berhak minimal.

Dari sisi CVE

1. Patch management terjadwal.
2. Vulnerability scanning berkala.
3. Asset inventory yang akurat.

Dari sisi privilege escalation

1. Audit SUID/SGID secara rutin.
2. Batasi aturan sudo.
3. Periksa permission cron dan script.
4. Gunakan SELinux/AppArmor bila sesuai.

Dari sisi data exfiltration

1. Secret management yang benar.
2. Encryption dan DLP (Data Loss Prevention).
3. Monitoring dan alert untuk akses data sensitif.
4. Network egress filtering.

Kesimpulan penting

Dalam praktik Boot2Root, enumerasi biasanya menentukan keberhasilan lebih dari eksploitasi. Banyak mesin sengaja dirancang agar petunjuk tersebar di konfigurasi, file backup, permission yang salah, atau reuse kredensial. Fokus pembelajaran terbaik adalah:

1. Memahami cara mengidentifikasi permukaan serangan.
2. Memahami mengapa suatu konfigurasi menjadi rentan.
3. Memahami cara memitigasi dan mendeteksinya.
4. Berlatih hanya di lab/CTF atau sistem yang Anda miliki izin eksplisit untuk diuji.

Jika Anda ingin, saya juga bisa membantu membangun mesin Boot2Root Easy untuk latihan atau menyusun checklist enumerasi Linux yang aman.